

ROLE PLAYBOOK · COMPLIANCE · V2.1

The Compliance Officer's AI Governance Playbook

Five controls for moving from AI policy to inventory, architecture, human review, evidence, and board reporting.

The operating principle

Policy tells people what is allowed. Architecture, review, evidence, and cadence prove it is controlled.

The compliance officer's role is no longer only to review policies after the fact. In an AI-enabled institution, compliance helps define the approved path before AI touches customer-facing work, retained records, regulated decisions, confidential data, or examiner-facing outputs.

WHAT'S INSIDE

- | | |
|---|-------------------------------|
| 1. Executive snapshot | 7. Five compliance plays |
| 2. The compliance landscape now | 8. Compliance templates |
| 3. The modern AI compliance operating model | 9. 90-day implementation plan |
| 4. Architectural compliance | 10. What success looks like |
| 5. Prepare vs. decide matrix | 11. Recommended AiBI path |
| 6. Risk-tiering model | 12. Final operating principle |

Who this is for

- Compliance Officers.
- Chief Risk Officers.
- Internal Audit partners.
- Legal and regulatory review teams.
- AI governance committee members.
- Department leaders proposing AI-supported workflows.
- Executives asking how to let teams use AI without losing control.

The core problem

AI adoption is happening faster than governance can be written. Employees want to use AI to summarize, draft, compare, explain, research, and automate. Vendors are embedding AI into products. Business teams are experimenting before controls are fully defined. Meanwhile, existing banking obligations still apply: adverse action rules, model risk management where applicable, third-party risk management, privacy and information security, fair lending, complaint handling, records retention, SAR confidentiality, and board oversight.

The compliance risk is not simply "AI is risky." The real risk is invisible AI use: no inventory, no review path, no data boundary, no evidence, no owner, and no record of how AI-supported work became official work.

The compliance opportunity

A practical AI compliance program does not need to start as a 200-page framework. It should start with:

1. A one-page acceptable use standard.
2. A living AI use-case inventory.
3. A risk-tiering model.
4. A human review standard.
5. A third-party AI intake question set.
6. An evidence packet for reviewed workflows.
7. A board-ready quarterly AI governance update.

What this playbook gives you

- A modern AI compliance operating model.
- Five practical compliance plays.
- Editable templates.
- A 90-day implementation plan.
- A use-case intake form.
- A risk-tiering framework.
- A workflow evidence packet.
- Board reporting structure.
- Controls for AI gateways, human review, and ongoing validation.

Existing rules still apply

There may not be one single AI-specific banking rulebook that tells every community bank exactly what to do. That does not mean the field is empty. The compliance officer should map AI use to existing obligations, including:

- Fair lending and adverse-action requirements.
- Model risk management expectations where AI supports quantitative, customer-impacting, regulated, or model-like decision processes.
- Third-party risk management.
- GLBA information-security obligations, the FTC Safeguards Rule where applicable, and parallel interagency information-security standards.
- Bank Secrecy Act / AML obligations.
- SAR confidentiality and investigation-detail protection.
- Complaint handling and UDAAP risk.
- Records retention.
- Board and management oversight.
- Vendor and subcontractor risk.

Model-risk scope without over-claiming

Current model-risk guidance, including SR 26-2 where applicable, should be considered when AI supports quantitative, customer-impacting, regulated, or model-like decision processes. Generative AI workflows used for drafting, summarization, training, documentation, or workflow support should be governed through approved-tool controls, data boundaries, human review, evidence retention, vendor oversight, and incident-response procedures.

The black-box excuse is over

If AI is used in a credit-related workflow, the institution must still be able to explain the actual reasons behind an adverse action. A complex algorithm is not a valid reason for failing to provide specific and accurate principal reasons.

If the bank cannot explain the decision, the bank cannot safely rely on the system.

This applies especially to credit decisioning, adverse action drafting, credit risk ranking, loan pricing support, credit-line recommendations, and informal AI scoring tools used by lending teams. AI may not select, infer, or invent principal reasons; it may only help express reasons already determined and documented by a qualified human reviewer.

SAR confidentiality is a hard boundary

No SAR, SAR draft, SAR existence, SAR-supporting detail, investigation note, alert detail, or information that would reveal the existence of a SAR may be entered into any public AI tool.

Use global AI regulation as directional context only

Even if a U.S. community bank is not directly subject to every international framework, global regulation can show where supervisory expectations may be heading. The EU AI Act treats creditworthiness and credit scoring as high-risk uses under Annex III; use that as directional context, not as a substitute for U.S. banking law, agency guidance, contract obligations, and institution-specific controls.

The safest U.S. posture is to build explainability, human review, data governance, and evidence retention now — before a specific examiner request forces the issue.

Five layers of a modern AI compliance program

Layer 1 · Policy

Policy sets the expectation. It answers: which tools are approved, what data may be used, which workflows are prohibited, which outputs require review, who owns exceptions, and what must be retained.

Layer 2 · Inventory

Inventory shows where AI is used. It captures use case, tool, department, user role, data class, risk tier, human reviewer, approval checkpoint, review cadence, and last-reviewed date.

Layer 3 · Architecture

Architecture enforces the rules. This may include an approved AI tools list, a central AI gateway or approved access path, role-based access controls, data-loss prevention rules, prompt and output logging, input sanitization, output validation, vendor restrictions, and private or enterprise AI environments. The point is not to buy more software for its own sake — it is to prevent policies from depending entirely on memory and good intentions.

Layer 4 · Human review

Human review defines where AI stops. The institution should explicitly identify who reviews the output, what they check, what sources they compare against, what gets escalated, what becomes final, and what is retained.

Layer 5 · Evidence and monitoring

Evidence proves control. Monitoring proves the workflow remains safe over time. For higher-risk AI use, compliance should expect review logs, output sampling, exception tracking, drift monitoring where applicable, model or tool change tracking, vendor refresh cadence, board reporting, and reassessment after material changes.

Policy must become a control

Written policies are necessary, but they are not enough. A policy says, "Do not paste customer data into public AI." A control helps ensure that customer data does not actually leave the approved environment.

What architectural compliance means

AI rules are embedded into the workflow, tool stack, or approval path. Examples: employees use an approved AI gateway instead of public tools; the gateway logs prompts and outputs; sensitive data patterns are blocked or flagged; tools are restricted by role and data class; high-risk workflows require approval before output is used; AI-assisted outputs are labeled as draft, reviewed, or approved; records are saved to an approved repository.

Central AI gateway pattern

A centralized AI gateway can route AI traffic through a controlled layer. Potential controls: approved model access, role-based permissions, prompt and output logging, data-loss prevention checks, token or usage limits, prohibited-data detection, human review triggers, and audit trail generation. Compliance does not need to own the gateway, but compliance should define the rules the gateway enforces.

Dual-layer guardrails

Input guardrails — before the request reaches the model

- Customer names.
- Account numbers.
- Social Security numbers.
- Dates of birth.
- Transaction-level detail.
- Confidential documents.
- Examiner correspondence.
- Legal or compliance determinations.
- Prompt-injection instructions.

Output guardrails — before the output is used

- Unsupported factual claims.
- Invented citations.
- Customer data leakage.
- Missing disclosures.
- Confident but unverifiable statements.
- Legal conclusions.
- Credit or adverse-action reasoning.
- Unapproved final decisions.

Private AI / enterprise AI pattern

Some workflows may require enterprise, private-cloud, or on-premises AI environments. This becomes more important when the workflow involves confidential internal procedures, customer NPI, regulated workflows, vendor data, security controls, AML / fraud data, customer communication, or credit / lending workflows.

The more sensitive the data and the more consequential the output, the more controlled the environment must be.

What AI can prepare and what humans must decide

WORKFLOW	AI CAN PREPARE	HUMAN MUST DECIDE	EVIDENCE RETAINED
Internal guidance summary	Plain-English summary, staff FAQ, training aid	Whether guidance is accurate and approved	Source, draft, reviewer, approved version
Marketing copy	Draft options, claim flags, disclosure checklist	Whether copy is approved for use	Draft, review checklist, compliance approval
Adverse-action support	Plain-language draft from human-provided principal reasons	Final reasons and final notice	File source, reviewer, final notice
Complaint response support	Draft response structure, issue summary	Final response and customer-impact decision	Complaint file, draft, reviewer, final response
BSA / AML support	Case structure, typology summary, missing-fact flags	SAR filing, investigation closure, alert disposition	Source notes, reviewer, final disposition
Vendor AI review	Intake summary, question list, contract issue flags	Vendor approval or rejection	Due diligence record, sign-off, conditions
Board update	Draft narrative and risk-tier summary	Final board report and governance decisions	Inventory, summary, board packet

Three lanes for compliance AI use

Green — generally safe with public, synthetic, or non-sensitive information

- Brainstorm training scenarios.
- Summarize public regulatory guidance.
- Draft internal learning aids.
- Create blank templates.
- Generate fictional practice cases.

Controls: no customer data; no confidential records; human review before distribution.

Yellow — approved tool, redaction, and human review required

- Customer-facing draft language.
- Internal summaries of policies.
- Procedure drafts.
- Marketing campaign copy.
- Complaint response drafts.
- Operational checklists.
- AI-assisted vendor review summaries.

Controls: approved tool only; data boundary documented; human reviewer identified; output labeled draft until reviewed; retention rule defined.

Red — restricted workflow requiring formal review and controlled environment

- Credit decisioning.
- Adverse-action reasoning.
- BSA / AML alert disposition.
- SAR filing decisions.
- Fraud investigation closure.
- Customer authentication or security controls.
- Legal or compliance determinations.
- Model-based decisions or rankings.

Controls: no public AI tools; approved enterprise environment only; compliance / legal / risk review; human decision required; evidence packet retained; model-risk or vendor-risk review as applicable.

PLAY 1

Issue a one-page AI acceptable use standard

Give every employee a plain-English expectation for AI use.

Why it matters

If AI appears in an exam, audit, complaint, or incident, one of the first questions will be: **What does your policy say?** A simple approved standard is better than a missing answer.

What the standard covers

- Approved tools.
- Prohibited tools.
- Data boundaries.
- Customer data rules.
- The review rule.
- Risk tiers.
- Escalation triggers.
- Output labeling.
- Retention expectations.

What it does not need on day one

- Full model-risk taxonomy.
- Quantitative validation plan for every AI use.
- Complete vendor inventory.
- 200-page AI governance framework.

EDITABLE CLAUSE LANGUAGE · AI ACCEPTABLE USE STANDARD SKELETON

Employees may use approved AI tools for drafting, summarizing, brainstorming, structuring, and training support when the input data is allowed and the output is reviewed before use.

Employees may not enter customer NPI, account information, confidential records, examiner correspondence, legal advice requests, or regulated decision information into public AI tools.

Any AI output that could affect a customer, examiner, policy, control, financial decision, complaint, credit action, or retained business record must be reviewed by a qualified human before use.

AI output must be labeled as draft, reviewed, or approved. Reviewed outputs must be retained

according to the applicable recordkeeping procedure.

When uncertain, classify the use case as higher risk and escalate to Compliance.

Artifact: one-page AI Acceptable Use Standard. **Metrics:** policy approved · employees notified · departments briefed · exceptions logged.

PLAY 2

Build the AI use-case inventory

Create a living inventory of where AI is used or proposed across the institution.

Why it matters

Compliance cannot govern invisible use. A simple working inventory gives compliance, risk, audit, and leadership a shared map.

Inventory fields

FIELD	WHAT GOES HERE
Use case	Plain-English description
Department	Who uses it
Tool	Vendor, product, model, or platform
User role	Who enters the request
Data class	Public / internal / confidential / customer NPI
Output type	Draft / summary / decision support / communication
Risk tier	Green / Yellow / Red
Human reviewer	Who signs off
Approval status	Proposed / piloting / approved / retired
Review cadence	Monthly / quarterly / annually
Last reviewed	Date
Evidence location	Where supporting records live

Sample rows

USE CASE	DEPARTMENT	TOOL	DATA CLASS	TIER	REVIEWER
Draft internal AI training summary	HR / Training	Approved assistant	Internal	Yellow	Training manager
Summarize branch FAQ themes	Retail	Approved assistant	Redacted / aggregate	Yellow	Retail ops lead
Draft adverse-action language	Lending	Controlled workflow only	Customer / credit	Red	Underwriter + compliance
Generate synthetic BSA training cases	BSA / AML	Approved assistant	Synthetic	Green	BSA officer

Artifact: AI use-case inventory. **Metrics:** use cases inventoried · percentage risk-tiered · percentage with named reviewer · number retired or escalated.

PLAY 3

Map third-party AI into TPRM

Update third-party risk management intake so AI-enabled vendor products are identified and reviewed.

Why it matters

AI inside a vendor product is still third-party risk. The compliance officer should not discover AI functionality only after a vendor is live.

Vendor intake questions

1. Does the product include AI, machine learning, generative AI, or automated decisioning functionality?
2. What function does the AI perform?
3. Is customer data processed by the AI system?
4. Is customer data used to train or improve models?
5. Where is data processed and stored?
6. What subprocessors are involved?
7. What logs are retained?
8. Can the institution opt out of model training?
9. What human review or override controls exist?
10. Does the AI touch credit, fraud, AML, authentication, complaints, or customer communications?
11. What documentation is available for model design, testing, limitations, monitoring, and incidents?
12. How does the vendor notify clients of material model or data-handling changes?

AI vendor verdict memo

FIELD	RESPONSE
Vendor / product	
Planning rationale	Business need, expected benefit, and why an AI-enabled product is being considered.
Due diligence status	Not started / in progress / complete / conditions outstanding.
Contract review status	Not started / legal review / approved / exceptions unresolved.
AI functionality	

FIELD	RESPONSE
Banking function supported	
Criticality	Critical / high / moderate / low, consistent with TPRM standards.
Data classes processed	
Data-use terms	What data the vendor may process, store, reuse, or disclose.
Model-training restriction	Opt-out, prohibition, or contract term limiting model training on bank or customer data.
Retention / deletion	Retention period, deletion process, and certification or evidence available.
Fourth-party / subprocessor review	Material subprocessors, data flow, and change-notice terms.
Breach notice	Notice timing, content, and escalation path.
Regulator / audit access	Contract rights, documentation access, and examination-support expectations.
Customer impact	
Regulatory area affected	
Risk tier	
Required controls	
Contract issues	
Approval decision	Approved / conditional / rejected
Ongoing monitoring owner	Name / role accountable after launch.
Next review date	
Termination / data-return plan	Exit steps, data return or destruction, and customer/operational continuity plan.

PLAY 4

Walk the credit / adverse-action path

Make sure any AI touching credit, denial support, customer explanation, or adverse action has documented human review.

Why it matters

Credit is the highest-stakes AI lane. If AI drafts or influences adverse-action language, the institution must still provide specific and accurate principal reasons based on the actual file.

RED LINE

Do not allow an AI system to generate, send, or finalize customer-facing adverse-action language without documented human review. Do not allow informal AI scoring or ranking of credit applications without model-risk and compliance review.

Required workflow

1. Human underwriter or qualified reviewer identifies principal reasons from the file.
2. AI may not select, infer, rank, or invent principal reasons; it may only help express reasons already determined and documented by a qualified human reviewer.
3. AI may draft clearer language only from those human-provided reasons.
4. Human reviewer compares every sentence to the source file.
5. Unsupported or invented language is removed.
6. Final notice is approved by the authorized reviewer.
7. Evidence packet is retained.

PLAY 5

Create the quarterly AI governance update

Give the board and executive team a repeatable view of AI usage, risk, changes, and next steps.

Why it matters

The board does not need a technical AI lecture. It needs a clear governance rhythm.

Board update structure

1. **Where AI is used.** Total use cases, count by risk tier, count by department.
2. **What changed.** New use cases, retired use cases, exceptions, vendor changes, incidents or near misses.
3. **What is coming.** Next use case under review, training needs, policy updates, vendor reviews, risk decisions needed.

Board dashboard table

METRIC	CURRENT QUARTER	PRIOR QUARTER	NOTES
Total AI use cases			
Green use cases			
Yellow use cases			
Red exceptions			
Use cases with named reviewer			
Use cases past review date			
Vendor AI reviews completed			
Training completions			

Artifact: Quarterly AI Governance Update. **Metrics:** board updates delivered · inventory completeness · review-cadence compliance · open issues closed.

The Compliance Officer's AI Governance Starter Kit

Package this playbook with the editable artifacts compliance needs to move from policy language to evidence: an AI acceptable-use standard, AI use-case intake form, vendor AI review memo, adverse-action control map, output review checklist, evidence packet template, and quarterly board dashboard.

Template 1 · AI use-case intake form

FIELD	RESPONSE
Use case name	
Department	
Business purpose	
Proposed tool	
User role	
Input data	
Data class	Public / Internal / Confidential / Customer NPI
Output type	Draft / Summary / Recommendation / Decision support
Customer impact	Yes / No
Regulatory area	Credit / BSA / Fraud / Marketing / Complaints / Operations / Other
Risk tier	Green / Yellow / Red
Human reviewer	
Approval checkpoint	
Retention rule	
Escalation trigger	
Approval decision	Approved / Conditional / Rejected

Template 2 · AI workflow SOP outline

1. Workflow name.
2. Business purpose.
3. Approved tool.
4. Allowed inputs.
5. Prohibited inputs.
6. AI output description.
7. Human reviewer.
8. Review standard.
9. Approval checkpoint.
10. Retention rule.
11. Escalation triggers.

Templates 3 & 4

Template 3 · AI output review checklist

- ☐ Output is labeled draft, reviewed, or approved.
- ☐ Source material was identified.
- ☐ Numbers, dates, citations, and claims were verified.
- ☐ Customer data was not entered into an unapproved tool.
- ☐ Output does not make legal, credit, compliance, or regulatory determinations.
- ☐ Human reviewer is authorized to approve the work.
- ☐ Escalation triggers were considered.
- ☐ Final version was saved in the approved location.

Template 4 · AI evidence packet

For each Yellow or Red use case, retain:

- ☐ Use-case intake form.
- ☐ Tool approval status.
- ☐ Data classification.
- ☐ Prompt or instruction.
- ☐ Source material description.
- ☐ AI output.
- ☐ Human reviewer.
- ☐ Reviewer changes.
- ☐ Final approved output.
- ☐ Approval date.
- ☐ Retention location.
- ☐ Next review date.

SECTION 9 · 90-DAY IMPLEMENTATION PLAN

From standing still to first quarterly cycle

Days 1 – 30 · Establish the baseline

Outcomes: one-page acceptable use standard approved; Safe AI Use Checklist distributed; Red / Yellow / Green Use Card distributed; AI use-case inventory started; first three use cases entered; Compliance and InfoSec agree on public-tool red lines.

Artifacts: acceptable use standard · use-case inventory · data boundary guide.

Days 31 – 60 · Build the review system

Outcomes: TPRM intake updated for AI functionality; top vendors reviewed for AI functionality; first Yellow use case reviewed and signed off; adverse-action workflow mapped if applicable; human review checklist adopted.

Artifacts: AI vendor review addendum · AI workflow SOP · output review checklist · credit / adverse-action control map.

Days 61 – 90 · Create the governance rhythm

Outcomes: inventory reaches at least 20 use cases or all known use cases; quarterly AI board update delivered; first reviewed workflow evidence packet completed; training plan assigned by role; exceptions and open risks documented.

Artifacts: quarterly AI governance update · evidence packet · training path map · 90-day compliance summary.

Nine questions the compliance officer can answer at day 90

1. What does your AI policy say?
2. Where is AI used in the institution?
3. Which tools are approved?
4. What data is allowed?
5. Which workflows are Green, Yellow, and Red?
6. Who reviews AI output?
7. What evidence is retained?
8. What changed since last quarter?
9. What use case is next?

The goal is not to eliminate AI risk. The goal is to make AI use visible, reviewed, explainable, and governed.

SECTION 11 · NEXT STEP

Run the 30-minute AI Compliance Baseline Sprint

Create your first acceptable-use standard, identify three AI use cases, classify risk tiers, assign reviewers, and build the first evidence packet.

1. Pick three known or likely AI uses: one low-risk drafting use, one vendor-embedded use, and one regulated workflow near credit, complaints, BSA/AML, or customer communications.
2. Write the data boundary for each use case: approved tool, allowed inputs, prohibited inputs, reviewer, and retention location.
3. Classify each use case as Green, Yellow, or Red and document the reason.
4. Assign the human reviewer and the escalation trigger.
5. Save the first evidence packet with intake form, source material description, AI output, reviewer changes, approval decision, and next review date.

Make the approved path easier than the shadow path

Compliance does not need to stop AI adoption. Compliance needs to make the approved path easier than the shadow path. That means clear rules, approved tools, visible inventory, human review, evidence packets, board cadence, and continuous monitoring.

AI can draft. AI can summarize. AI can structure. AI can accelerate. But the institution still owns the decision, the customer impact, the retained record, and the control environment.

Sources: ECOA / Regulation B and CFPB adverse-action guidance; Federal Reserve SR 26-2 and parallel 2026 agency model-risk updates where applicable; Interagency Third-Party Risk Management Guidance; GLBA information-security obligations, FTC Safeguards Rule where applicable, and parallel interagency information-security standards; SAR confidentiality rules; EU AI Act Annex III creditworthiness / credit-scoring classification as directional context only; AIEOG AI Lexicon (US Treasury / FBIIC / FSSCC, February 2026); Financial Services AI Risk Management Framework; GAO-25-107197 (May 2025); AiBI Foundations curriculum.

This playbook is a starter artifact, not legal advice or an examiner-approved policy. Adapt before adoption and route final compliance language through the institution's normal compliance, risk, legal, and board governance process.